

Como conectar com MFA e SSO

Guia de alto nível para consumir as APIs

Público: times técnicos de produto, integração e sustentação.

Não é um cookbook de código — é o mapa do processo.

Referência detalhada: [docs/login-mfa-sso-api.md](#)

Regra de ouro

Microsoft prova quem é a pessoa. O TOTP Linx prova o 2º fator da empresa.

1. Em uma frase

Para entrar no Linx UX por API você não chama um único endpoint de login. Sua aplicação percorre quatro etapas: provar identidade (senha ou Microsoft), descobrir o ambiente/GPECON, cumprir o MFA Linx e só então abrir a sessão de Application.

O Portal faz isso no browser. Um cliente desktop ou de integração fala direto com o Service (LinxFrameworkAutorizacao). O cookie Forms do Portal não autoriza o Application sozinho.

2. Quem faz o quê

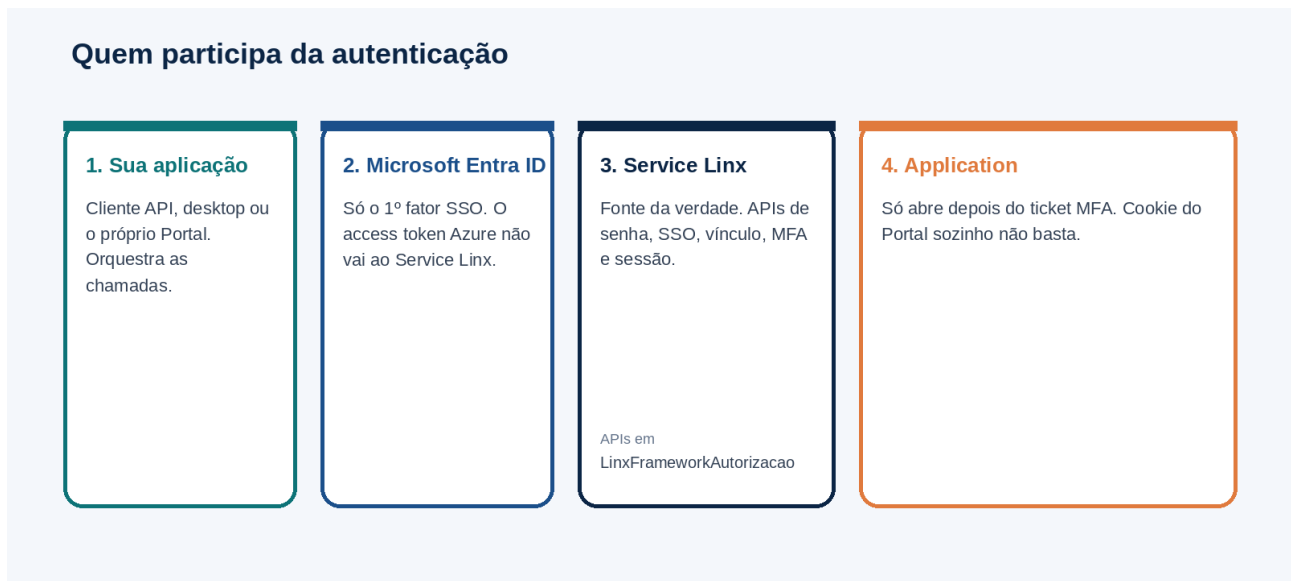


Figura 1 — Peças do fluxo. O Service é a fonte da verdade; o Portal só orquestra no browser.

O Microsoft Entra ID participa apenas do primeiro fator SSO. O access token Azure nunca é enviado ao Service. O Service só recebe o login local Linx (NomeAutenticacao) e, no vínculo, o OID e o UPN.

3. As quatro etapas, nesta ordem



Figura 2 — As quatro etapas obrigatórias, nesta ordem.

Duas regras de produto que evitam a maior parte dos erros de integração:

- MFA não roda na tela de senha/SSO. Ele só começa depois que o GPECON (IdLinxGpecon) é conhecido.

- SSO Azure não substitui o TOTP Linx. Quem entrou com Microsoft ainda precisa do código de 6 dígitos, se a empresa estiver com MFA ligado.

4. Etapa 1 — Provar identidade

Há dois caminhos. Os dois terminam no mesmo lugar: um usuário Linx autenticado no 1º fator, ainda sem Application.

4.1 Caminho com senha

Caminho A — login com senha (API)

Sua aplicação

GET AuthenticatePortal

Envelope criptografado: `Encrypt(Encrypt(usuário)||Encrypt(senha))`

Service

Resposta 1 || nome

Primeiro fator OK. Ainda sem MFA e sem sessão de Application.

Sua aplicação

POST PortalUserAccess

Lista ambientes. Guarde `IdLinxGpecon`, `UidEmpresa`, `UidAplicacao`.

Segue para MFA

próxima figura

Com o GPECON em mãos, chame `GetMfaStatus`.

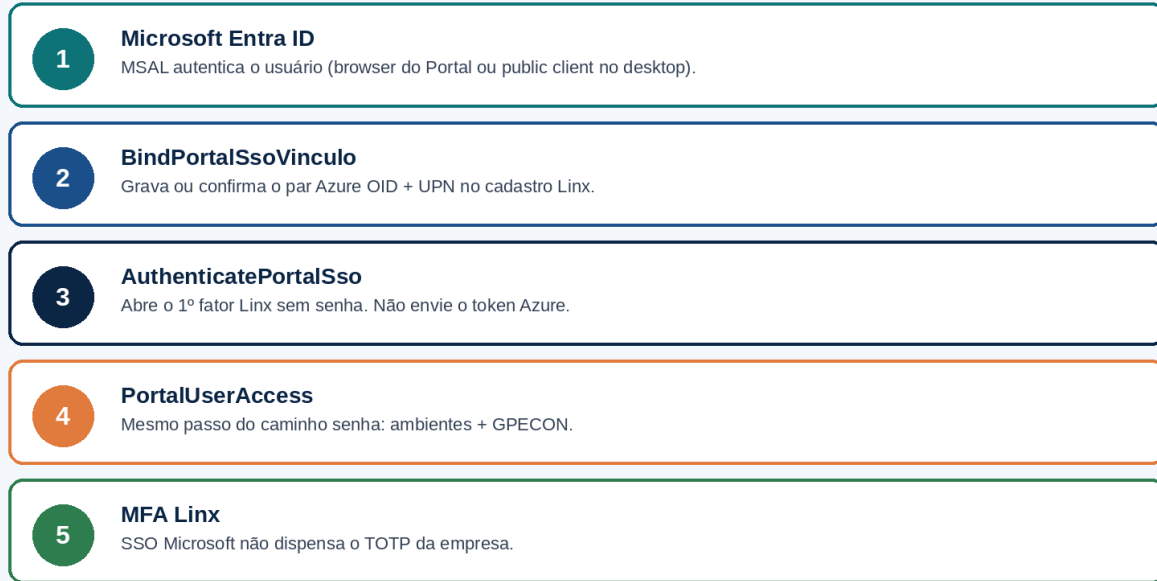
Figura 3 — Caminho com senha até chegar no MFA.

```
GET {ServiceUrl}/LinxFrameworkAutorizacao/AuthenticatePortal?authenticateParameters=...
```

O parâmetro é um envelope da criptografia do produto (`Linx.Security.Cryptography`): `Encrypt( Encrypt(usuário) + "||" + Encrypt(senha) )`. Não reimplemente o algoritmo — use a DLL do Framework. Sucesso descriptografa para `1 || NomeUsuario || NomeCurtoUsuario`.

4.2 Caminho com Microsoft (SSO)

Caminho B — login com Microsoft (SSO) via API



Se o OID Azure for outro já vinculado (SSOF-LINK), o Service recusa e não abre sessão.

Figura 4 — Caminho Microsoft. O token Azure não entra no Service.

No browser, o Portal redireciona para a Microsoft e volta em `/Account/SsoCallback`. No desktop, use MSAL public client (sem secret) e extraia o UPN. O Service não valida o token Azure — ele confia que o Azure já autenticou neste processo.

```
GET .../BindPortalSsoVinculo?userName=LOGIN&azureOid=OID&azureUpn=UPN
GET .../AuthenticatePortalSso?userName=LOGIN
```

O `userName` é o login Linx (NomeAutenticacao da tela CONTINUAR). Se não houver sessão, o Portal usa o prefixo do UPN antes do `@`. Não chame `AuthenticatePortalSso` com um login inventado.

Vínculo Azure ↔ Linx (o que o SSO grava)



Figura 7 — O que acontece no vínculo da conta Microsoft com o usuário Linx.

Se a API de vínculo responder HTTP 404 Not Found, o Service daquele ambiente ainda não tem `BindPortalSsoVinculo`. Atualize `Linx.Framework.BV.dll` e `Linx.Framework.BV.WebAPI.DS.dll` e recicle o pool. Isso não é “usuário sem cadastro”.

5. Etapa 2 — Ambiente e GPECON

Com o 1º fator OK, liste os acessos do usuário. É daqui que saem o GPECON do MFA e os UIDs da sessão.

```
POST {ServiceUrl}/LinxFrameworkUsuarioAutorizacao/PortalUserAccess
```

```
{ "NomeAutenticacao": "usuario.local", "AcessoLocal": false, "Parametros": "<Encrypt(\\\"\\\")>" }
```

Parametros não pode ser string vazia — o Service quebra no Decrypt. Envie `crypto.Encrypt("")`, como o Portal. Contra IIS remoto use `AcessoLocal=false`.

De cada linha, conserve no mínimo:

- `IdLinxGpecon` — GPECON da ficha do usuário (é o MFA).
- `UidUsuario`, `UidEmpresa`, `UidAplicacao`, `IdTcsAmbiente`.
- Se houver `IndicaAcessoPadrao` ou um único ambiente, siga sem pedir escolha.

6. Etapa 3 — MFA Linx (TOTP)

O MFA é da empresa no Linx, não o MFA da Microsoft. Sem linha em `TCS_GPECON_MFA`, MFA está ligado. No cadastro do usuário, `INDICA_UTILIZA_MFA` nulo também significa ligado.

Etapa 3 — decisão do MFA (GetMfaStatus)

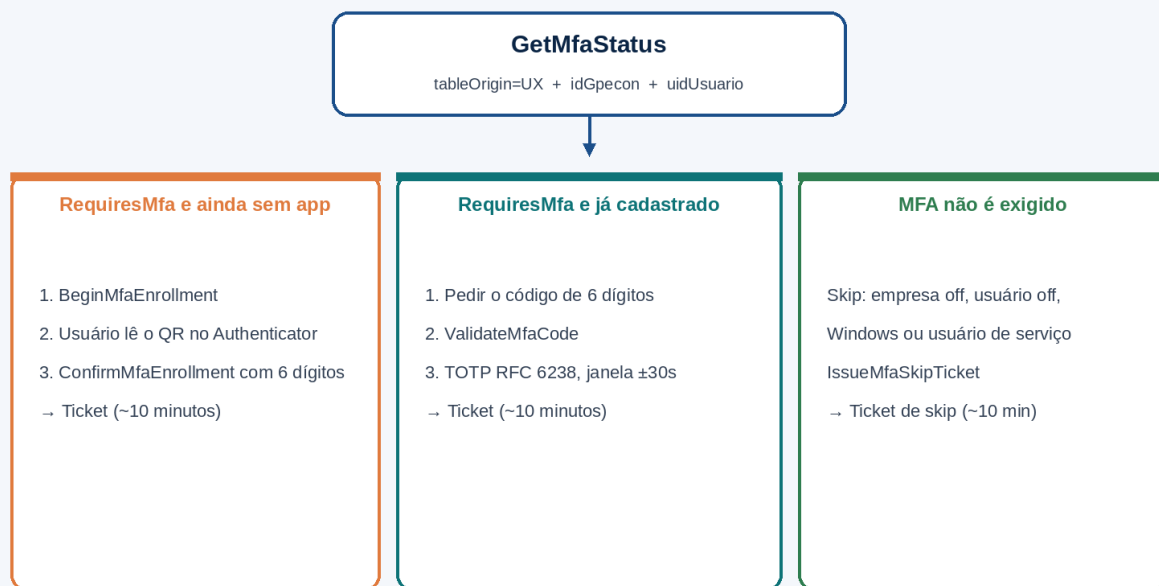


Figura 5 — Depois do GPECON, o `GetMfaStatus` decide enroll, código ou skip.

API	Quando usar	Resultado
GetMfaStatus	Sempre, depois do GPECON	RequiresMfa, Enrolled, SkipReason
BeginMfaEnrollment	Primeira vez (sem app)	QR (PNG Base64) + otpauth://
ConfirmMfaEnrollment	Usuário digitou o 1º código	Ativa o secret e emite ticket
ValidateMfaCode	Já cadastrado no Authenticator	Confere 6 dígitos e emite ticket
IssueMfaSkipTicket	RequiresMfa = false	Ticket de skip, mesmos 10 minutos

API	Quando usar	Resultado
ValidateMfaTicket	Antes de AuthenticateUser	Confirma que o ticket ainda vale

```
GET .../GetMfaStatus?tableOrigin=UX&idGpecon=123&uidUsuario={guid}
GET .../ValidateMfaCode?tableOrigin=UX&idGpecon=123&uidUsuario={guid}&code=123456&canal=Portal
```

Quando o MFA é pulado (UX)

Condição	SkipReason
Usuário de serviço (só API; Portal bloqueia)	INDICA_USUARIO_SERVICO
Autenticação Windows	AUTENTICACAO_WINDOWS
Empresa com MFA desligado	COMPANY_MFA_OFF
Usuário com “Utiliza MFA” = 0	USER_MFA_OFF

Usuário de serviço não entra pelo Portal (erro ERRAUT022). Nas APIs com canal Service/Desktop ele entra e o MFA é pulado. SSO Microsoft nunca é motivo de skip.

7. Etapa 4 — Abrir a sessão de Application

Etapa 4 — o ticket abre o Application

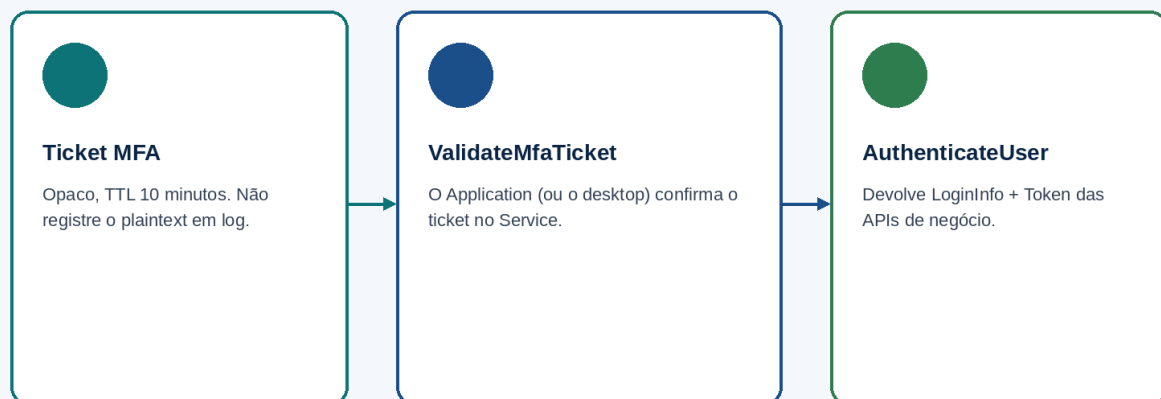


Figura 6 — O ticket MFA é o passe de 10 minutos para AuthenticateUser.

```
GET .../ValidateMfaTicket?ticket={ticket}
GET .../AuthenticateUser?authenticatedUser=LOGIN&applicationId={uidApp}&companyId={uidEmpresa}&accessGroupId=00000000-0000-0000-0000-000000000000&environmentId=1
```

No browser, o Portal redireciona para `LIA/Authentication?mfaTicket=...`. O Application aceita o ticket na querystring ou no header `MfaTicket`. No desktop, chame as duas APIs acima e use o Token do `LoginInfo` nas APIs de negócio.

8. Receita mínima (checklist)

#	Senha	SSO Microsoft
1	AuthenticatePortal (envelope Encrypt)	MSAL → BindPortalSsoVinculo → AuthenticatePortalSso
2	PortalUserAccess → escolher ambiente	Igual ao caminho senha
3	GetMfaStatus → enroll / código / skip	Igual — SSO não pula MFA
4	Guardar Ticket (≤ 10 min)	Igual
5	ValidateMfaTicket + AuthenticateUser	Igual

9. O que não fazer

- Não encaminhar o access token da Microsoft ao Service.
- Não tratar o cookie do Portal como sessão do Application.
- Não chamar AuthenticateUser antes do ticket (quando RequiresMfa=true).
- Não logar secret TOTP, URI otpauth completa nem o plaintext do ticket.
- Não usar o registro Web do Portal (com secret) como app desktop — desktop é public client.
- Não apontar só o Portal novo para um Service antigo: BindPortalSsoVinculo vai responder 404.

10. APIs de apoio

API	Papel
GetPortalLoginOptions	Antes do CONTINUAR: flags SSO/MFA, e-mail para login_hint, se é usuário de serviço
LogPortalSsoProcess	Trilha do SSO em TCS_LOG_ACESSO_AUTH (I = passo, F = falha sem lockout)
CheckPortalSsoVinculo	O cadastro pergunta se já existe OID/UPN gravado
RevokePortalSsoVinculo	Botão Revogar SSO — apaga só o vínculo
RevokeMfaSecret	Botão Revogar MFA — próximo acesso é enroll de novo

11. Onde ler o detalhe

Este PDF é o mapa. Contratos JSON, DTOs C# e exemplos HttpClient estão em docs/login-mfa-ss-api.md e docs/login-mfa-ss-desktop-dotnet.md. Texto para usuário final: docs/login-mfa-ss-usuario.md.

Base do Service em QA típico: http://<host>:1710/. Origem MFA neste delivery: sempre tableOrigin=UX.